

ARCHITECTURE REPORT

Pharma Aggregator Marketplace

Backend & Database Architecture — Current State

Backend repo	pharma-aggregator-server
Frontend repo	pharma-aggregator-client
Stack	Spring Boot 4.0.1 · Java 21 · PostgreSQL · Next.js 16
Generated	2026-08-14
Scope	Read-only codebase survey — no source changes made

Contents

1. System Overview
2. Backend Architecture
 - a. Layered Structure & Packages
 - b. DTO / Mapper Layer
 - c. API Response Wrapper
 - d. Security Architecture
 - e. Exception Handling
 - f. Build & Dependencies
 - g. Controller / API Inventory
3. Database Architecture
 - a. Engine & Schema Management
 - b. Entity Relationship Overview (Core Domains)
 - c. Core Table Definitions
 - d. Relationship Map
 - e. Master / Lookup Tables
 - f. Product Domain (55+ entities)
 - g. Buyer Domain (Full Detail)
4. Known Gaps & Recommendations

1. System Overview

The platform is a two-repo pharmacy marketplace: a Next.js 16 (App Router) frontend and a Spring Boot backend backed by PostgreSQL. Two user roles are actively built out on the frontend — **seller** (registration → admin approval → dashboard → product management) and **buyer** (currently a landing-dashboard stub). There is **no admin UI in the frontend**, though the backend has partial admin endpoints for seller/buyer approval.

Layer	Technology	Notes
Frontend	Next.js 16, React, Tailwind v4 + MUI + Bootstrap, react-hook-form + Zod	Two axios clients (<code>lib/api.ts</code> with refresh handling, <code>utils/api.ts</code> without) used inconsistently by domain
Backend	Spring Boot 4.0.1, Java 21 (compiler target; <code>java.version</code> property says 17)	Layered controller → service → repository → entity, manual DTO/mapper layer (no MapStruct)
Database	PostgreSQL	Schema is created by Hibernate <code>ddl-auto</code> , not versioned migrations
Auth	JWT (HS256, jjwt 0.11.5) + random refresh tokens (DB-stored)	Filter chain wired but authorization currently permits all requests — see §4d
File/Doc storage	AWS S3 (<code>S3Config</code>), iText PDF, Apache POI (Excel)	Used for seller documents, certificates, product import/export
Messaging	Spring Mail, Twilio SDK	Email/SMS OTP flows

2. Backend Architecture

2a. Layered Structure & Packages

Standard top-down dependency flow: `controller` → `service` (interface) → `service.serviceImpl` / domain-specific impl packages → `repository` → `entity`. The direction is consistent; naming of the implementation package is not (`service/seller/sellerImpl`, `service/serviceImpl/temp/seller`, `service/product/productImpl`, and a generic `service/impl` all coexist).

Domain packages mirror each other across `entity`, `dto`, `repository`, `service`, and `controller`: `auth`, `seller`, `temp.seller`, `buyer`, `temp.buyer`, `master`, `product`, `admin`, `ifsc`.

Exception to the interface/impl pattern: `service/buyer/BuyerAuthService` and `service/buyer/BuyerSignupService` are concrete `@Service` classes with no separate interface — unlike the temp-buyer and admin-approval services, which do follow interface + `ServiceImpl`.

2b. DTO / Mapper Layer

A full `dto/` tree mirrors the domain packages. Object mapping is done by **34 hand-written mapper classes** under `mapper/` — no MapStruct or other codegen is used.

- **Product mappers (23):** one per attribute/lookup entity — `ProductDetailsMapper`, `PricingDetailsMapper`, `ProductImageMapper`, `ProductAttributeDrugMapper`, `MoleculeMapper`, `GstPercentageMasterMapper`, etc., plus one attribute mapper per product category.
- **Seller mappers:** `SellerAddressMapper`, `SellerBankDetailsMapper`, `SellerCoordinatorMapper`, `SellerDocumentMapper`, `SellerGSTMMapper`, `SellerMapper` — plus a **second, differently-scoped** `SellerMapper` under `mapper/seller/AllSeller/` for admin list views, and `SellerByIdMapper` / `SellerProfileMapper`.
- **Master mapper:** `ProductTypeMapper`.
- **Orphan mappers:** `TestMapper`, `EmployeeMapper` — tied to the unused `Employee` entity, not wired into any live flow. GAP

2c. API Response Wrapper

`response.ApiResponse<T>` (`status`, `message`, `data`, `count`) is applied globally by `GlobalResponseHandler` (`@RestControllerAdvice` implements `ResponseBodyAdvice<Object>`), wrapping every controller response that isn't already an `ApiResponse`.

Inconsistency: two unrelated `ApiResponse` classes exist — `response.ApiResponse` (the global success wrapper) and `dto.seller.SellerLogIn.ApiResponse` (used only by the error handler). `GlobalResponseHandler` has to explicitly check for both types to avoid double-wrapping. A third class, `response.ErrorResponse`, is used solely by `GlobalExceptionHandler.handleBaseException`.

2d. Security Architecture

Component	Class	Behavior
Config	<code>config/SecurityConfig.java</code>	<code>@EnableWebSecurity</code> , <code>@EnableMethodSecurity</code> , CSRF disabled, session policy <code>STATELESS</code>
Entry point	<code>security/AuthEntryPointJwt.java</code>	Returns JSON 401 body (<code>status/error/message/path</code>) on auth failure

JWT filter	<code>security/AuthTokenFilter.java</code>	<code>OncePerRequestFilter</code> , registered before <code>UsernamePasswordAuthenticationFilter</code> ; reads <code>Authorization: Bearer</code> , validates via <code>JwtUtils</code> , loads user via <code>UserDetailsServiceImpl</code>
JWT utility	<code>security/JwtUtils.java</code>	HS256 (jwt 0.11.5); token holds only <code>subject=username</code> + issued/expiry — no roles/sellerId claims
CORS	<code>config/CrossConfig.java</code>	<code>CorsFilter</code> on <code>/**</code> ; hardcoded allowed origins incl. localhost:3000 and 4 deployed hosts; <code>allowCredentials(true)</code>

Critical gap: `authorizeHttpRequests(auth -> auth.anyRequest().permitAll())` — the entire path-allowlist block (public vs. authenticated routes) is commented out. **Every endpoint is currently publicly reachable** at the HTTP layer. The JWT filter still runs and populates the security context when a token is present, but nothing enforces it. `@EnableMethodSecurity` is declared but **zero** uses of `@PreAuthorize` / `@Secured` / `@RolesAllowed` exist anywhere — role data (`RoleMaster`) is stored but not enforced. **SECURITY**

JWT secret and the "30-minute" access-token expiry comment disagree with the actual configured value (`86400000` ms = 24h, left over from a "temporarily... change back to production" note). Secret is a plaintext literal in `application-dev.yml` / `application-test.yml` , not sourced from env/secret manager.

2e. Exception Handling

Two separate advice classes coexist rather than one unified handler:

GlobalExceptionHandler	HTTP Status
<code>BaseException</code> (+ subclasses)	status carried on exception
<code>MethodArgumentNotValidException</code>	400
<code>ResourceNotFoundException</code>	404
<code>BadRequestException</code>	400
<code>UnauthorizedException</code>	401
<code>ResponseStatusException</code>	passthrough
<code>Exception</code> (catch-all)	500

GlobalLogInExceptionHandler	HTTP Status
<code>MethodArgumentNotValidException</code>	400
<code>InvalidCredentialsException</code>	401
<code>AccountLockedException</code>	403
<code>AccountInactiveException</code>	403
<code>Exception</code> (catch-all)	500

Unhandled exception types (fall through to generic 500 instead of a semantic 4xx): `DuplicateRequestException` , `ValidationException` , and all of `exception/auth/*` — `OtpExpiredException` , `OtpInvalidException` , `OtpLockedException` , `RefreshTokenException` . **GAP**

2f. Build & Dependencies

Item	Value
Spring Boot	4.0.1 (starter parent)
Java	compiler target 21 (pom <code>java.version</code> property says 17 — inconsistency)
Web	spring-boot-starter-webmvc
API docs	springdoc-openapi-starter-webmvc-ui 2.3.0 (Swagger routes are among the ones meant to be public, currently moot since everything is public)
JWT	io.jsonwebtoken (jwt) 0.11.5
Mail / SMS	spring-boot-starter-mail, Twilio SDK 9.15.0
File storage	AWS S3 SDK 2.25.60
PDF / Excel	iText 7.2.5, Apache POI 5.2.5, commons-io, commons-csv
Migrations	flyway-core present but unused — no migration files anywhere
Mapping	none (manual mappers, no MapStruct)

Caching / messaging	none (no Redis, Kafka, RabbitMQ)
Boilerplate	Lombok 1.18.30 (pinned, overriding parent-managed version)

2g. Controller / API Inventory

Base path: `/api/v1` (context-path). Grouped by domain; methods are the exposed HTTP verbs per controller, not full route detail.

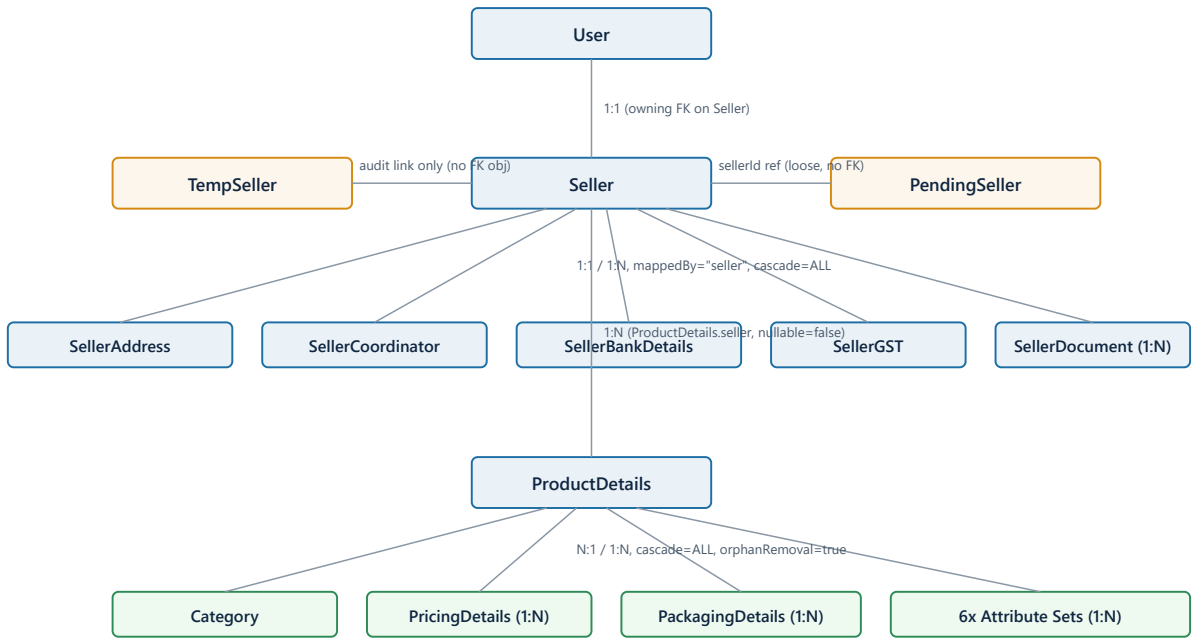
Domain	Controller	Representative Routes
Auth	SignupController	POST /auth/signup
	AuthController	/auth/* (seller login)
	AuthenticationController	/authentication/*
Seller	SellerProfileController	PUT /sellers/{id}/request-update , GET /sellers/user/{userId} , POST /sellers/{id}/documents/upload , DELETE /sellers/pendingSellerId/{id} , GET /sellers/product-types , GET /sellers , DELETE /sellers/{id}
	AdminSellerApprovalController	GET /admin/seller-requests/pending/{id} , GET /admin/seller-requests/{sellerId} , POST .../approve , .../reject , .../batch-approve
	AdminSellerController	POST /admin/sellers/review
	TempSellerController	/temp-sellers/*
	TempSellerEmailOtpController	temp-seller/email-otp/* (missing leading slash — style inconsistency)
	SMSOTPController	/otp/*
	IndependentEmailController	/independent/email/*
Buyer	BuyerSignupController	POST /buyer/auth/signup , POST /buyer/auth/signup/verify-otp
	BuyerAuthenticationController	POST /buyer/authentication/login , .../verify-otp , .../refresh , .../logout
	AdminBuyerController	POST /admin/buyers/review (ACCEPT/REJECT/CORRECTION — single-record only, no list/pending endpoint)
	TempBuyerController	/temp-buyers full CRUD + workflow: create, list, get by id, get by userId, verify gst/pan/document, delete, delete-both, uniqueness checks (email/phone/gst/pan/document), document upload/delete, update, draft create/update/finalize
	BuyerTypeMasterController	/buyer-types/* (master data)
Master/lookup	8 small CRUD controllers	/states , /districts , /talukas , /company-types , /seller-types , /buyer-types , /product-types , /document-types
Product	ProductDetailsController	/products/*
	ProductImportController	/products/import
	ExcelProductImportController	@RequestMapping commented out
	MastersController	/masters/* (aggregate lookups)
	PricingController , StockController , image/document/manual controllers	/pricing , /stock , /product-images , /product-documents , /userManual
	~14 lookup controllers	/ageGroup , /dosage , /drugCategory , /flavours , /molecules , /strengthUnit , /packType , /gst-percentages , /storageConditions , /therapeutic , etc.
Misc	IFSCOverrideController , HomeController	/ifsc/* ; root health check

3. Database Architecture

3a. Engine & Schema Management

- **Engine:** PostgreSQL (dev: `pharma_aggregator_test_local` , prod: `pharma-aggregator`).
- **Schema management:** `hibernate.ddl-auto=update` in dev, `validate` in prod. **No Flyway/Liquibase migrations exist** despite `flyway-core` being a declared dependency — the only migration-adjacent artifact is a manual seed script, `db/seed/strength_unit_seed.sql` . GAP
- Practical implication: prod schema has no reproducible, versioned history — it depends on whatever a prior dev `update` run produced.

3b. Entity Relationship Overview (Core Domains)



Core seller + product cluster. Blue = seller identity, orange = draft/approval workflow tables, green = product domain entry point.

3c. Core Table Definitions

tbl_user (User)

Column	Type	Constraints
userId	Long	PK, IDENTITY
username	String(100)	unique, not null
passwordHash	String	not null (BCrypt)
isPasswordTemporary	boolean	not null, default true
isActive	boolean	not null, default true
isAccountLocked	boolean	not null, default false
failedLoginAttempts	int	not null, default 0
lastLoginAt	LocalDateTime	
resetPasswordToken / Expires	String(255) / LocalDateTime	
passwordResetOtp / Expires	String / LocalDateTime	
roles	Set<RoleMaster>	M:N, tbl_user_roles, FetchType.EAGER
loginOtps	Set<LoginOtp>	1:N, cascade=ALL, orphanRemoval
refreshTokens	Set<RefreshToken>	1:N, cascade=ALL, orphanRemoval
createdAt / updatedAt	LocalDateTime	timestamps

tbl_seller (Seller)

Column	Type	Constraints
sellerId	String	PK (natural key)
sellerName	String	
tempSellerId	Long	audit-only, no FK object
approvedAt	LocalDateTime	
sellerImageUrl	String	

parentManufacturerName / brandOwnerName	String(100)	
companyType	CompanyTypeMaster	N:1, not null
sellerType	SellerTypeMaster	N:1, not null
phone	String(100)	not null
isPhoneVerified	boolean	not null
email	String(100)	not null
isEmailVerified	boolean	not null
website	String	
status	String(100)	not null (free-text: Approved / Correction_required / Rejected — not a Java enum)
termsAccepted	boolean	not null, default false
companyRegistrationCertificateUrl	String	not null, DB default 'PENDING'
isCompanyRegistrationCertificateVerified	boolean	not null, default false
user	User	1:1 owning, unique, not null, cascade=ALL, orphanRemoval
createdBy / updatedBy	String(100)	
createdAt	LocalDateTime	@CreationTimestamp, not updatable
updatedAt	LocalDateTime	@UpdateTimestamp
isActive	Boolean	default true

tbl_temp_seller (TempSeller)

Column	Type	Constraints
tempSellerId	Long	PK, IDENTITY
tempSellerRequestId	String(100)	not null
user	User	1:1, unique, nullable
sellerName / sellerImageUrl / parentManufacturerName / brandOwnerName	String	
gstNumber / gstFileUrl / gstFileName	String(100) / String	
isGstVerified	boolean	not null, default false
companyType / sellerType	CompanyTypeMaster / SellerTypeMaster	N:1, nullable (unlike Seller)
phone / email	String(100)	nullable (unlike Seller)
isPhoneVerified / isEmailVerified	boolean	not null
website	String	
status	String(100)	not null (open / In Progress / Closed)
termsAccepted	boolean	default false
companyRegistrationCertificateUrl / FileName	String	DB default 'PENDING'
isCompanyRegistrationCertificateVerified	boolean	not null, default false
createdBy/updatedBy, createdAt/updatedAt	String / LocalDateTime	audit + timestamps
isActive	Boolean	default true

Contains commented-out dangling fields (a duplicate `termsAccepted`, an old `@ManyToOne productTypes`) — leftover from refactoring.

tbl_pending_seller (PendingSeller) — denormalized approval-request snapshot

Column	Type	Constraints
pendingSellerId	Long	PK, IDENTITY
sellerId	String	nullable — original seller if requestType=UPDATE, loose ref, no FK object
sellerName	String	
state / district / taluka	StateMaster / DistrictMaster / TalukaMaster	N:1

city / street / buildingNo / landmark / pinCode	String	inlined, not a satellite entity
coordinatorName / Designation / Email / Mobile	String	inlined
bankName / Branch / IfscCode / AccountNumber / AccountHolderName / DocumentFileUrl	String	inlined
gstNumber / gstFileUrl	String	inlined
companyType / sellerType	CompanyTypeMaster / SellerTypeMaster	N:1
phone / email / website	String	
termsAccepted	boolean	
companyRegistrationCertificateUrl	String	
requestType	String	not null (CREATE / UPDATE)
status	String	not null, default PENDING (PENDING/APPROVED/REJECTED)
requestedBy / approvedBy	String	
approvedAt	LocalDateTime	
rejectionReason	String	
documents	List<PendingSellerDocument>	1:N, cascade=ALL, orphanRemoval
productTypes	List<ProductTypeMaster>	M:N via tbl_pending_seller_product_types
createdAt / updatedAt / isActive	LocalDateTime / Boolean	default true

tbl_buyer_user (BuyerUser)

Column	Type	Constraints
buyerUserId	Long	PK, IDENTITY
email	String(100)	unique, not null
phone	String(15)	
passwordHash	String	not null
isEmailVerified / isPhoneVerified	boolean	not null, default false
isActive	boolean	not null, default true
isAccountLocked	boolean	not null, default false
failedLoginAttempts	int	not null, default 0
lastLoginAt	LocalDateTime	
resetPasswordToken / Expires	String(255) / LocalDateTime	
createdAt / updatedAt	LocalDateTime	timestamps

No JPA relations are declared on BuyerUser itself — the buyer business objects (Buyer , BuyerAddress , BuyerContact , BuyerDocument , BuyerDeliveryAddress) key off a separate Buyer entity, not visibly linked to BuyerUser in what was inspected — worth confirming how buyer auth and buyer profile are tied together. TO VERIFY

tm_product_details (ProductDetails)

Column	Type	Constraints
productId	String	PK (natural key, not generated)
productName	String	
warningsPrecautions / productDescription	String	TEXT column
manufacturerName	String	
createdBy / modifiedBy	String	
createdDate	LocalDateTime	not updatable
modifiedDate	LocalDateTime	

category	Category	N:1, not null
seller	Seller	N:1, not null
packagingDetails / pricingDetails / productImages	Set<...>	1:N, cascade=ALL, orphanRemoval
6x productAttribute* sets (Drug, NonConsumableMedical, Consumable, SupplementsOrNutraceuticals, FoodInfant, CosmeticandPersonalCare)	Set<...>	1:N each, cascade=ALL, orphanRemoval — only the set matching the product's actual category is populated
gstPercentage / hsnCode	Long	
status	ProductStatus (enum)	not null, VARCHAR(20) DEFAULT 'PUBLISHED'

3d. Relationship Map

From	To	Cardinality	Notes
Seller.user	User	1:1	owning, unique FK, cascade=ALL, orphanRemoval
Seller.address	SellerAddress	1:1	mappedBy, cascade=ALL, orphanRemoval
Seller.coordinator	SellerCoordinator	1:1	mappedBy, cascade=ALL, orphanRemoval
Seller.bankDetails	SellerBankDetails	1:1	mappedBy, cascade=ALL, orphanRemoval
Seller.sellerGST	SellerGST	1:1	mappedBy, cascade=ALL, orphanRemoval
Seller.documents	SellerDocument	1:N	mappedBy, cascade=ALL, orphanRemoval; also FK to DocumentTypeMaster/ProductTypeMaster
Seller.productTypes	ProductTypeMaster	M:N	tbl_seller_product_types
Seller.companyType / sellerType	CompanyTypeMaster / SellerTypeMaster	N:1	not null
Seller.productDetails	ProductDetails	1:N	mappedBy, cascade=ALL, orphanRemoval
Seller.tempSellerId	TempSeller.tempSellerId	loose ref	plain Long, no FK relation object
TempSeller.user	User	1:1	nullable, no cascade declared
TempSeller.address/coordinator/bankDetails	TempSeller* satellites	1:1	mappedBy, cascade=ALL, orphanRemoval
TempSeller.documents	TempSellerDocument	1:N	mappedBy, cascade=ALL, orphanRemoval
TempSeller.reviewHistories	TempSellerReviewHistory	1:N	mappedBy, cascade=ALL, orphanRemoval
TempSeller.productTypes	ProductTypeMaster	M:N	tbl_temp_seller_product_types
PendingSeller.state/district/taluka	StateMaster/DistrictMaster/TalukaMaster	N:1	
PendingSeller.documents	PendingSellerDocument	1:N	mappedBy, cascade=ALL, orphanRemoval
PendingSeller.productTypes	ProductTypeMaster	M:N	tbl_pending_seller_product_types
User.roles	RoleMaster	M:N	tbl_user_roles, FetchType.EAGER
User.loginOtps / refreshTokens	LoginOtp / RefreshToken	1:N	mappedBy, cascade=ALL, orphanRemoval
ProductDetails.seller	Seller	N:1	not null; inverse of Seller.productDetails
ProductDetails.category	Category	N:1	not null
ProductDetails.packagingDetails/pricingDetails/productImages	respective entities	1:N	mappedBy, cascade=ALL, orphanRemoval
ProductDetails.6x attribute sets	ProductAttribute* entities	1:N	mappedBy, cascade=ALL, orphanRemoval; one set per super-category

3e. Master / Lookup Tables

Geography hierarchy: StateMaster → DistrictMaster → TalukaMaster . Type/role lookups referenced across domains: CompanyTypeMaster , SellerTypeMaster , BuyerTypeMaster , ProductTypeMaster , DocumentTypeMaster , RoleMaster .

3f. Product Domain (55+ entities)

The product package is the largest single domain. ProductDetails is the hub, joined to six category-specific attribute tables that mirror the frontend's per-category service files 1:1 (Drug, Consumable Medical, Non-Consumable Medical, Supplements/Nutraceuticals, Food/Infant, Cosmetic/Personal Care), plus a long tail of shared lookup masters:

- **Clinical/dosage:** DrugCategory, DosageForm, Flavour, Molecule, MoleculeStrengthFormat, StrengthUnit, ProductMolecule (composite key join)

- **Packaging/commercial:** PackType, PackTypeUnitMaster, NetQuantityUnit, ServingSizeUnit, GstPercentageMaster, PricingDetails, PackagingDetails, ProductImage, SpecialSchemes, AdditionalDiscount
- **Category structure:** Category, ProductCategoryMaster, ProductSubcategoryMaster, ProductFormMaster, TherapeuticCategoryMaster, TherapeuticSubcategoryMaster, AgeGroupMaster
- **Medical device sub-domain:** MedicalDeviceProductMaster.* (Certification, CertificateDocument, ConsumableMaterialType, CountryMaster, DeviceCategory, DeviceSubCategory, DeviceSpecificationUnit, DimensionSize, MedicalDeviceType, NonConsumableMaterialType, PowerSource, StorageConditionMaster)
- **Cosmetic sub-domain:** CosmeticPersonalCareMasters.* (HairType, IntendedUseArea, ProductsFormMaster, SkinType)
- **Inventory:** StockLedger
- **Documents:** ProductCertificateDocument, ProductUserManualDocument/ProductUserManual

3g. Buyer Domain (Full Detail)

The buyer domain mirrors the seller domain's registration/approval shape (signup → OTP → temp draft → admin review → promoted profile) but is materially thinner: no change-request table, no dedicated profile-management API, and — confirmed by grep — **zero connection to any commerce/ordering entity**. No `Order`, `Cart`, `Wishlist`, or `Checkout` entity exists anywhere in the codebase; `StockLedger` links only to `Seller` / `ProductDetails` / `PricingDetails`, never to `Buyer`. The buyer side today is registration/auth only.

`tbl_buyer_user` (BuyerUser — auth/credentials)

Same shape as documented in §3c; repeated here for completeness. Holds **no** relation fields to `Buyer` — it is a pure credentials row, referenced only *from* other entities.

`tbl_buyer` (Buyer — business/profile entity)

Column	Type	Constraints
buyerId	String	PK — built as [2-char org abbr][buyer-type abbr][4-digit seq], e.g. <code>TIRE0001</code>
tempBuyerId	Long	audit-only, no FK object (same loose-link pattern as <code>Seller.tempSellerId</code>)
approvedAt	LocalDateTime	
organizationName	String(150)	
orgLogoUrl	String	
buyerType	BuyerTypeMaster	N:1, LAZY
address	BuyerAddress	1:1, mappedBy, cascade=ALL, orphanRemoval
contact	BuyerContact	1:1, mappedBy, cascade=ALL, orphanRemoval
documents	List<BuyerDocument>	1:N, mappedBy, cascade=ALL, orphanRemoval
deliveryAddresses	List<BuyerDeliveryAddress>	1:N, mappedBy, cascade=ALL, orphanRemoval
gstNumber / gstFileUrl	String(100) / String	
isGstVerified	boolean	not null, default false
panNumber / panFileUrl	String(100) / String	
isPanVerified	boolean	not null, default false
status	String(100)	not null (free-text, e.g. "APPROVED")
termsAccepted	boolean	default false
user	BuyerUser	1:1 owning FK, column <code>buyer_user_id</code> , not null, unique, LAZY, @JsonIgnore — the real, DB-enforced link to BuyerUser
createdBy / updatedBy, createdAt / updatedAt	String / LocalDateTime	audit + timestamps
isActive	Boolean	default true

How BuyerUser links to Buyer (resolved): `Buyer` is the owning side of a real `@OneToOne` to `BuyerUser` (`buyer_user_id`, NOT NULL, UNIQUE) — `BuyerUser` carries no relation back. Lookup in practice is `BuyerRepository.findByUser_BuyerUserId(buyerUserId)`, used only by the temp-buyer deletion flow. **The login/OTP/JWT flow (`BuyerAuthService`, `BuyerAuthenticationController`) never touches `Buyer` at all** — it authenticates purely against `BuyerUser` and issues a JWT with no profile data attached. There is no endpoint today that resolves "logged-in buyer → their Buyer profile." GAP

Buyer satellite tables

Table / Entity	Key columns	Relation to Buyer
----------------	-------------	-------------------

<code>tbl_buyer_address</code> (BuyerAddress)	state/district/taluka (FK to master tables), city, street, buildingNo, landmark, pinCode	1:1, owning side (unique, not null FK back to Buyer)
<code>tbl_buyer_contact</code> (BuyerContact)	name, designation, email (unique), isEmailVerified, mobile (unique), isPhoneVerified	1:1, owning side
<code>tbl_buyer_document</code> (BuyerDocument)	documentType (FK), documentNumber, documentFileName/Name, isDocumentVerified, licenseIssueDate/ExpiryDate, licenseIssuingAuthority, licenseStatus	N:1 (1:N from Buyer)
<code>tbl_buyer_delivery_address</code> (BuyerDeliveryAddress)	label, state/district/taluka/city/street/buildingNo/landmark/pinCode — plain strings, not master-table FKs (inconsistent with BuyerAddress), isDefault	N:1 (1:N from Buyer)
<code>tbl_buyer_refresh_tokens</code> (BuyerRefreshToken)	buyerUser (FK), tokenHash (SHA-256, unique), expiresAt, revokedAt	N:1 to BuyerUser (not Buyer)
<code>tbl_buyer_login_otp</code> (BuyerLoginOtp)	buyerUser (FK), otpCode(6), expiresAt, isUsed, failedAttempts, isLocked	N:1 to BuyerUser
<code>tbl_buyer_signup_otp</code> (BuyerSignupOtp)	email, phone, otp, passwordHash (held until OTP verified), expiryTime, verified	none — BuyerUser doesn't exist yet at signup time

TempBuyer cluster — draft/approval workflow

Table / Entity	Key columns	Relation
<code>tbl_temp_buyer</code> (TempBuyer)	tempBuyerRequestId, organizationName, orgLogoUrl, gstNumber/panNumber(+verified flags), status, termsAccepted	<code>user</code> → BuyerUser 1:1 nullable (draft can predate login link); <code>address</code> / <code>contact</code> 1:1 mappedBy cascade=ALL; <code>documents</code> / <code>reviewHistories</code> 1:N mappedBy cascade=ALL; <code>buyerType</code> N:1
<code>tbl_temp_buyer_address</code>	mirrors BuyerAddress exactly (master-table FKs)	1:1 owning back to TempBuyer
<code>tbl_temp_buyer_contact</code>	mirrors BuyerContact exactly (unique email/mobile)	1:1 owning back to TempBuyer
<code>tbl_temp_buyer_document</code>	mirrors BuyerDocument; <code>documentFileUrl</code> DB-defaults to 'PENDING' ; <code>@PrePersist/@PreUpdate</code> auto-computes <code>licenseStatus</code>	N:1 to TempBuyer
<code>tbl_temp_buyer_review_history</code>	status (CORRECTION_REQUIRED/REJECTED/APPROVED, free-text), comments (TEXT), reviewedBy, reviewedAt	N:1 to TempBuyer
<code>TempBuyerStatus</code>	not an entity — a constants class (DRAFT, SUBMITTED, UNDER_REVIEW, APPROVED, CORRECTION_REQUIRED, REJECTED, SUSPENDED), compared via <code>equalsIgnoreCase</code>	mirrors <code>TempSellerStatus</code> by design

Promotion workflow (TempBuyer → Buyer)

`AdminBuyerController` POST `/admin/buyers/review` → `BuyerApprovalServiceImpl.processReview()` (explicitly documented in code as mirroring `SellerApprovalServiceImpl` 's structure):

- CORRECTION** → status set to `CORRECTION_REQUIRED` , review-history row written, notification email sent.
- REJECT** → status set to `REJECTED` , review-history row written, email sent.
- ACCEPT** → `handleApproval()` : requires `tempBuyer.getUser() != null` (throws if the draft was never linked to a `BuyerUser`); generates the `buyerId` , deep-copies address/contact/documents into new rows under a new `Buyer` , sets the `tempBuyerId` audit link and status `APPROVED` ; then best-effort: sends approval email, physically moves S3 files from `tempbuyers/{REQ_ID}/...` to `buyers/{BUYER_ID}/...` and updates the DB URLs.

No post-approval update path exists. `TempBuyerServiceImpl.updateTempBuyer()` explicitly throws once `status == APPROVED` ("You are not allowed to update this application because it is already approved."). There is no `PendingBuyer` change-request table (matching the seller-side finding that this pattern isn't symmetric either — sellers have `PendingSeller` , buyers have nothing), no `BuyerProfileController` , and the address/contact/document/delivery-address repositories exist but expose **no service or controller at all** — they're wired for cascade persistence through `Buyer` only. The only mutation path found post-approval is `TempBuyerController DELETE /temp-buyers/both/{id}` , which deletes the `Buyer` and its `TempBuyer` draft together — i.e., today's only "update" mechanism is delete-and-resubmit-from-scratch. **GAP**

4. Known Gaps & Recommendations

Area	Gap	Severity
Security	All HTTP routes are effectively <code>permitAll()</code> — path-based auth rules are commented out; no method-level <code>@PreAuthorize</code> anywhere despite role data existing	Critical

Security	JWT secret committed in plaintext in dev/test YAML; access-token expiry (24h) contradicts its own "30 minutes for production" comment	High
Schema mgmt	Flyway dependency unused; prod relies on <code>ddl-auto=validate</code> against a schema no migration ever created — no reproducible history	High
Exception handling	<code>DuplicateRequestException</code> , <code>ValidationException</code> , and 4 OTP/refresh-token exceptions surface as generic 500s instead of correct 4xx	Medium
Admin surface	No admin list/dashboard/stats endpoints anywhere; buyer approval workflow lacks the seller side's dedicated pending-list/batch-approve controller — and there's no admin UI on the frontend at all to consume any of it	Medium
Buyer domain	Login/OTP/JWT flow never resolves the logged-in <code>BuyerUser</code> to their <code>Buyer</code> profile — no endpoint or service call does this today, only an unused repository method (<code>findByUser_BuyerUserId</code>)	Medium
Buyer domain	No post-approval profile update path at all — <code>TempBuyerServiceImpl</code> blocks edits once approved, there's no <code>PendingBuyer</code> change-request table, and no <code>BuyerProfileController</code> /address/contact/document controllers exist. Only mutation is delete-both-and-resubmit	High
Buyer domain	Buyer side has zero connection to commerce — no <code>Order</code> / <code>Cart</code> / <code>Wishlist</code> entity exists anywhere; <code>StockLedger</code> only links Seller/Product/Pricing, never Buyer	Medium (by design at this stage)
Data model	<code>BuyerDeliveryAddress</code> stores state/district/taluka as plain strings while <code>BuyerAddress</code> uses proper master-table FKs — inconsistent geography modeling within the same entity cluster	Low
Code hygiene	Orphan <code>Employee</code> entity + <code>EmployeeMapper</code> / <code>TestMapper</code> ; two unrelated <code>ApiResponse</code> classes; duplicate <code>SellerMapper</code> classes; dangling commented-out fields in <code>TempSeller</code> ; disabled <code>ExcelProductImportController</code> ; inconsistent Java version property vs. compiler target (17 vs 21)	Low
Testing	Only the default Spring Boot context-load smoke test exists — no unit/integration coverage for services, controllers, or repositories	Medium

Generated by static code analysis of the backend and frontend repositories. Reflects source as of 2026-08-14 — re-generate after significant schema or security changes.